

ACTIVITY PACK

Activity 2: Discussion Questions

Activity 2 - Prompt Injection and the PDPA-Reportable Leak

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	2.1 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Discussion Questions

Activity 2 - Discussion Questions

Prompt Injection and the PDPA-Reportable Leak

Work through all five questions in your group. Nominate one person to present your findings and your notification recommendation in the debrief. You have 60 minutes.

You are writing for a board, not for engineers. Where you make a recommendation, say what it costs.

Q1 - Anatomise the payload (K4)

Read Artefact 1 line by line. It is short, and every line is doing work.

- Identify the **four distinct manipulations** in the payload and name what each one is trying to achieve - one reframes the earlier context, one manufactures authority, one issues the task, one suppresses evidence.
- CLARA's system prompt says "never disclose personal data of other claimants." Explain **why** that instruction **lost** to a comment inside an uploaded DOCX. Your explanation must be in terms of how a transformer consumes its context window, not "the model made a mistake."
- The payload was hidden in a document comment in white 8pt text, and repeated in an OCR-readable photograph. State which OWASP 2026 entry covers each vector, and explain why the image version is the one Meridian's existing filter could never have caught.

Q2 - Explain how a "human in the loop" failed (K4)

The launch memo relied on the fact that an assessor presses Send.

- Walk through the 11:02 - 11:04 sequence in Artefact 3 and identify **every point** at which a control could have fired but did not. There are at least four.
- The to field was model-editable and the override was logged as to_field=OVERRIDDEN. Explain why this single design choice converted a data-disclosure bug into a data-**exfiltration** channel, and what the equivalent design rule should have been.
- Priya reviewed the email body and missed the recipient. Rather than blaming her, state what the workbench asked her to do that no human doing 60 claims a day can reliably do - and what that implies about where an approval gate must sit to be worth anything.

Q3 - The corpus was poisoned too (K1)

Artefact 4 is a second, quieter incident that nobody was looking for.

- Explain how 41 unauthorised chunks entered the policy corpus and were retrieved 1,140 times without anyone noticing. Identify **which properties of the ingestion pipeline** made this possible - consider ingestion controls, provenance, integrity verification and monitoring separately.
- Distinguish this from the DOCX injection. One is a **transient** manipulation of a single inference; the other is a **persistent** change to what the system believes. State the different detection method each one requires.
- Quantify the exposure a board would care about: if that paragraph biased even a fraction of the 1,140 retrievals toward waiving independent survey on claims above S\$8,000, what is the failure mode, and who benefits? Name the OWASP 2026 entries that apply to the corpus and to the unsigned vendor sync.

Q4 - Make the PDPA notification decision (K1, K4)

You must give the board a yes or no tomorrow, with reasons.

- Apply the PDPA data breach notification obligation to Artefact 5. Address **both** limbs -

significant harm to affected individuals, and significant scale - and state your conclusion on each separately. Say what you would notify, to whom, and within what timeframe.

- Rebut the Head of Digital's note. Deal with both of its claims: that a malicious upload makes this

customer conduct, and that a human pressing Send transfers responsibility. Use the PDPC's 2026 guidelines on personal data in generative AI, and be specific about which of the three roles - model provider, system provider, system deployer - Meridian occupies.

- Meridian's data inventory lists the claims database and the document store. It does not list

prompts, model outputs, or tool-call activity data. Explain why the 2026 guidelines make that a problem, and what it means for Meridian's ability to answer an access or correction request from one of the 118 individuals.

Q5 - Design the controls, and price them (K4, K1)

CLARA is currently switched off. The claims backlog is growing at roughly 400 claims a week.

- Propose **five** controls that must be in place before CLARA is re-enabled, in priority order.

At least two must be **architectural** - changes to what the system can read or do - rather than changes to the prompt or the model.

- For each control, state precisely what it costs: latency, engineering effort, assessor productivity,

money, or answer quality. A control list that pretends the controls are free will be challenged.

- The platform team proposes "a stronger system prompt with delimiters and a warning never to obey

instructions found in documents." Say what this buys and what it does not, and where it should sit in your priority list - including whether it belongs there at all.

- Recommend the **re-enablement posture**: full restore, restore in a reduced mode, or keep off. If

reduced, define exactly which of CLARA's three jobs and two tools come back, and what evidence would justify restoring the rest.